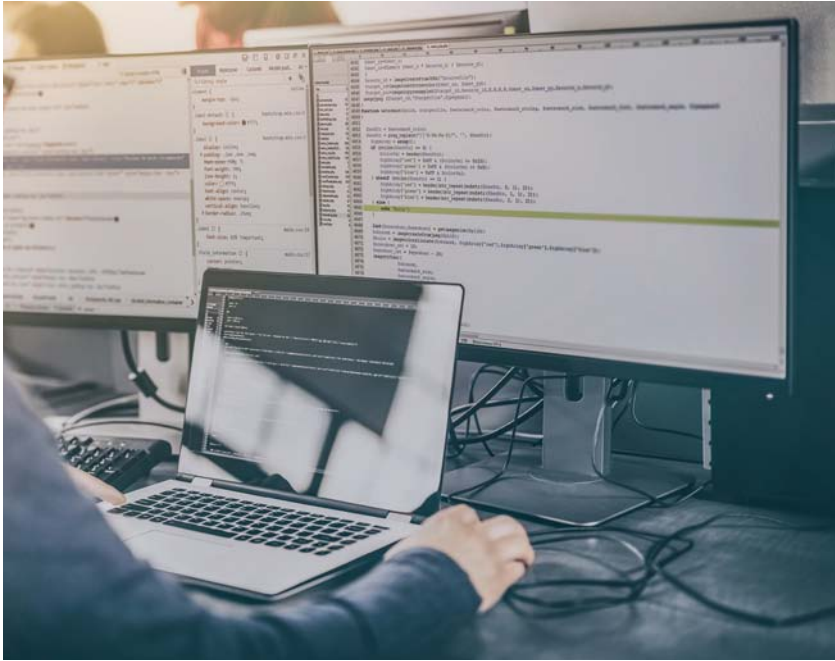


## OpenSSF launches npm Best Practices Guide



The npm Best Practices Guide has been made available by the Open Source Security Foundation (OpenSSF) to assist JavaScript and TypeScript developers in lowering the security risks connected with using open source dependencies. The manual, produced by the OpenSSF Best Practices Working Group, focuses on npm's dependency management and supply chain security and addresses a number of topics, including how to set up a secure CI configuration, how to avoid dependency confusion, and how to minimise the effects of a hijacked dependency.

The release coincides with developers sharing and using dependencies more frequently, which can pose problems while also accelerating innovation and development. Contributors to OpenSSF noted in a blog post that while adopting open source dependencies frequently has more advantages than disadvantages, there can also be major risks involved.

According to David A. Wheeler, the Linux Foundation's director of open source supply chain security: "Underestimating the potential impact of vulnerabilities in both direct and indirect dependencies is the biggest security risk associated with developers' use of open source dependencies. However, creating a strategy for dependency security that works can be difficult since it entails a unique set of issues that most developers aren't used to dealing with."

The npm Best Practices manual is intended to help developers and organisations dealing with such issues so they may more securely and confidently consume dependencies. It gives an overview of the supply chain security options offered by npm, discusses the dangers of using dependencies, and offers suggestions for risk mitigation at various project phases. A large part of the manual is devoted to dependency management, outlining actions developers can take to lessen potential risks.

## Notesnook is now open source

New note-taking app Notesnook, which prioritises privacy, has become open source. The app, which is among the top Linux note-taking applications, is end-to-end encrypted.

To allow the community to contribute to its improvement and ensure the project's longevity, Notesnook recently became open source under the GPLv3 licence. The developers plan to first concentrate on making the GitHub repository better before adding additional features and engaging in other development tasks.

Notesnook is a zero-knowledge notes storage platform. You can use it for free or choose the premium plan to gain access to a few more features, similar to Standard Notes.

Notesnook is providing up to a 75 per cent discount on its yearly premium plan, which comes with a 30-day money-back guarantee, to commemorate being open source. Try it out first to decide if you want the premium plan. There is an 80 per cent savings when looking at the Indian offering, putting the cost of a year's subscription at only US\$ 10. For other regions, it can be different. For further information, visit its GitHub page or the official website.

